

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 27

Domain III - Information Security Program

50 Questions	80 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 80 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM7-058)

Scenario: An equipment insurer is introducing usage-based coverage supported by connected sensors and continuous customer data. Its program was designed for annual policy administration.

Which basis should guide the new security program objectives?

- A. The security tools already purchased for office systems
- B. The service model, data uses, customer obligations, technology dependencies, and resulting risks
- C. The practices of one competing insurer
- D. The controls requiring no operational change

Question 2 (CISM7-059)

Scenario: A university and hospital create a shared research center. Each assumes the other will define security requirements, approve exceptions, and monitor shared platforms.

Which mandate action should occur FIRST?

- A. Approve a program charter defining objectives, scope, decision rights, responsibilities, sponsorship, and escalation across both institutions.
- B. Publish detailed configuration standards before assigning authority.
- C. Transfer all program responsibilities to the platform provider.
- D. Allow each project to choose its own security governance.

Question 3 (CISM7-060)

Scenario: A food-delivery company will enter two countries earlier than planned. Regional data requirements, local support, and supplier oversight are not scheduled until after launch.

Which roadmap adjustment is MOST appropriate?

- A. Reassess expansion risks and dependencies, then resequence funded capabilities around the launch milestones.
- B. Add all work without changing funding or other priorities.
- C. Keep existing dates because the roadmap was approved.
- D. Launch first and address regional security gaps later.

Question 4 (CISM7-061)

Scenario: A city, transit operator, and parking vendors share data for a mobility service. No participant controls the entire service, and responsibilities at system interfaces are unclear.

Which scoping approach is BEST?

- A. Limit scope to systems owned by the city.
- B. Make the transit operator accountable for every participant's risk.
- C. Exclude vendor-managed information flows.
- D. Map the end-to-end service, data, obligations, dependencies, risks, and responsibilities at each interface.

Question 5 (CISM7-062)**Which information BEST supports a vulnerability-management resource estimate?**

- A. The security department's current organizational chart
- B. The number of vulnerability products available in the market
- C. Asset scope, risk tiers, demand, service targets, skills, and automation
- D. A peer company's annual security budget

Question 6 (CISM7-063)

Scenario: A small financial cooperative needs help maintaining security documents but lacks a dedicated policy specialist. Internal leaders retain knowledge of business obligations and approval authority.

Which sourcing arrangement is MOST appropriate?

- A. Let a consultant approve policy and accept related risk.
- B. Use qualified external drafting and research support under internal ownership, review, approval, and knowledge-transfer requirements.
- C. Stop maintaining documents until a full-time employee is hired.
- D. Ask internal audit to own all security policies.

Question 7 (CISM7-064)

Scenario: A telecommunications provider proposes automating several repetitive control workflows. Processes are inconsistent, ownership is unclear, and source-system data quality varies.

Which orchestration business-case analysis would BEST support the investment decision?

- A. A business case covering risk reduction, process benefits, ownership and data prerequisites, implementation effort, and total cost
- B. A ranking based on the number of automation features
- C. A comparison based only on license price
- D. A promise that automation will remove every control failure

Question 8 (CISM7-065)

Scenario: A rapidly expanding retailer has capable operations staff but insufficient security architecture and control-assurance expertise for its planned platform transformation.

Which workforce-planning action should occur FIRST?

- A. Give every security employee the same basic course.
- B. Transfer missing management capabilities to internal audit.
- C. Hire only for the role with the highest market salary.
- D. Create a competency plan combining targeted development, recruitment, succession, and selective external support.

Question 9 (CISM7-066)

Who normally implements storage and protection requirements defined by an information owner?

- A. The risk committee
- B. The information custodian
- C. The independent auditor
- D. The policy approver

Question 10 (CISM7-067)

Which inventory practice BEST supports governance of derived analytics datasets?

- A. Record only the storage platform used by each dataset.
- B. Update the inventory only during annual audit preparation.
- C. Assign every derived dataset to the analytics tool administrator.
- D. Record business purpose, accountable owner, source information, classification, location, dependencies, and lifecycle status.

Question 11 (CISM7-068)

Scenario: A travel company records customer calls but has no consistent rules for access, transcription, sharing, retention, or deletion based on information sensitivity.

Which program change would BEST address the gap?

- A. Keep every recording indefinitely with the same access.
- B. Define classification-based handling requirements and embed them in recording, transcription, sharing, and disposal workflows.
- C. Require the security manager to approve every playback.
- D. Measure only the total number of recorded minutes.

Question 12 (CISM7-069)

Scenario: A research consortium completes a five-year study. Data remains in partner workspaces, and no owner has confirmed which records must be preserved, returned, restricted, or destroyed.

Which closure action should occur FIRST?

- A. Delete every copy immediately.
- B. Let workspace administrators decide retention independently.
- C. Confirm accountable ownership and applicable business, contractual, ethical, and legal requirements before controlled disposition.
- D. Keep all copies indefinitely to avoid a decision.

Question 13 (CISM7-070)

What does a security framework PRIMARILY provide to a program?

- A. Automatic acceptance of residual risk
- B. A guarantee of compliance with every obligation
- C. A structured reference for organizing and assessing relevant security capabilities
- D. A universal mandate for identical technologies

Question 14 (CISM7-071)

Which criterion should receive the MOST weight when selecting a security framework?

- A. Its fit with organizational objectives, risks, obligations, capabilities, and governance
- B. The number of pages in the framework
- C. Its popularity with a single technology supplier
- D. Its promise to eliminate the need for tailoring

Question 15 (CISM7-072)

Scenario: An acquired company uses different assurance frameworks from its parent. Similar requirements are implemented and tested separately, increasing cost and confusing control owners.

Which framework-integration action is MOST appropriate?

- A. Discard every acquired-company requirement.
- B. Build a separate control for every framework statement.
- C. Map requirements to a common control and evidence model while retaining traceability to unique obligations.
- D. Use only the framework containing the fewest requirements.

Question 16 (CISM7-073)

Which document normally states specific mandatory requirements supporting a security policy?

- A. Guideline
- B. Procedure
- C. Program roadmap
- D. Standard

Question 17 (CISM7-074)

Why should operating procedures be traceable to approved policies and standards?

- A. To make every procedure apply to every business process
- B. To show that operational steps implement authorized requirements and can be maintained consistently
- C. To allow procedure authors to accept business risk
- D. To prevent procedures from changing between policy reviews

Question 18 (CISM7-075)

Scenario: A clinical research team must use a partner exchange service that cannot meet a new file-retention standard for four months. The project proposes interim deletion reviews.

Which exception conditions should be required?

- A. Permanent exclusion of all research partnerships from the standard
- B. Informal approval by the project administrator
- C. Documented risk, accountable approval, compensating reviews, monitoring, review triggers, and a defined expiration
- D. A statement that the partner has not reported an incident

Question 19 (CISM7-076)

Scenario: A remote-work policy permits personal devices, while a data standard prohibits restricted records on unmanaged devices. A new workflow requires employees to access those records remotely.

Which document-governance action should occur FIRST?

- A. Let employees choose whichever document is more convenient.
- B. Engage accountable owners to reconcile the requirements using business and risk needs, then approve and communicate aligned rules.
- C. Assume the newer document automatically overrides the other.
- D. Suspend all remote work until every security document is rewritten.

Question 20 (CISM7-077)

Scenario: A retailer is replacing batch integrations with event-driven services. Project teams propose inconsistent authentication, event integrity, and monitoring designs.

Which security architecture action should occur FIRST?

- A. Define security principles and shared capability requirements aligned with the target enterprise architecture and risk scenarios.
- B. Allow each team to define separate security principles.
- C. Require all projects to purchase one product suite.
- D. Delay security architecture until the new integrations are operating.

Question 21 (CISM7-078)

Scenario: A bank's acquired systems cannot immediately use the target identity and logging services. Business integration must proceed in stages over two years.

Which transition-planning activity would provide the MOST value?

- A. Approve permanent exceptions for all acquired systems.
- B. Create a gap and dependency analysis defining transition states, interim safeguards, owners, priorities, and convergence milestones.
- C. Require immediate migration without considering service disruption.
- D. Replace the target architecture with an inventory of acquired products.

Question 22 (CISM7-079)

Scenario: A recruitment platform requires regional services to collect only information needed for defined hiring purposes. Architecture diagrams do not show how collection and downstream use are constrained.

Which traceability evidence should the manager request?

- A. A statement that the design follows current trends
- B. A list of every server model in each region
- C. Links from approved data requirements to architecture decisions, data flows, control ownership, and acceptance criteria
- D. Transfer of architecture approval to the platform provider

Question 23 (CISM7-080)

Scenario: A software group subjects low-risk internal tools and critical customer platforms to the same lengthy architecture review. Teams bypass the process to meet release dates.

Which governance redesign is MOST appropriate?

- A. Exclude every internal tool from security requirements.
- B. Introduce risk-tiered reviews, reusable patterns, early engagement, and a governed exception route.
- C. Approve projects according to cost alone.
- D. Make internal audit responsible for solution design.

Question 24 (CISM7-081)

Scenario: A hospital group can consolidate audit data through a rapid central cutover or phased regional migration. The cutover is faster, while phasing limits clinical disruption but needs temporary reconciliation.

Which roadmap recommendation is BEST?

- A. Compare resilience, dependencies, interim controls, impact, cost, and exit criteria
- B. Choose the fastest plan because speed always lowers risk.
- C. Retain fragmented audit data indefinitely.
- D. Let each region define a separate permanent target.

Question 25 (CISM7-082)

Which metric BEST reflects the outcome of secure-development governance?

- A. Hours spent configuring a scanning tool
- B. Number of training slides shown to developers
- C. Trend in material defects escaping to production, segmented by service risk and development stage
- D. Number of meetings attended by security staff

Question 26 (CISM7-083)

Scenario: A dashboard shows that privileged-access reviews meet the enterprise target, but several critical subsidiaries report repeated overdue reviews. The dashboard provides only a global average.

Which analysis would MOST improve management decisions?

- A. Trends by subsidiary, service criticality, accountable owner, backlog age, exception, and root cause
- B. The length of the access policy
- C. The number of executives who opened the report
- D. The number of colors in the dashboard

Question 27 (CISM7-084)

Scenario: A fast-growing software company has uneven program maturity. Management proposes raising every capability to the same level despite different business reliance and risk.

Which capability-target approach is BEST?

- A. Set the maximum level for all capabilities because uniformity guarantees acceptable risk.
- B. Fund only the capabilities with the lowest current scores.
- C. Stop using maturity information in program decisions.
- D. Set differentiated targets using risk, business dependence, desired outcomes, dependencies, affordability, and expected value.

Question 28 (CISM7-085)

What is the MOST important characteristic of a suitable security control design?

- A. It addresses a defined objective and risk within applicable requirements and operating constraints.
- B. It is identical to a peer's implementation.
- C. It creates the greatest possible restriction.
- D. It uses the newest technology.

Question 29 (CISM7-086)

Scenario: A public benefits portal proposes a single identity-verification method that many eligible users with limited documentation cannot complete.

Which control-selection response is MOST appropriate?

- A. Design accessible alternative verification with accountability and monitoring
- B. Use the single method because the strictest control always reduces total risk.
- C. Remove identity verification from the portal.
- D. Let users choose whether verification applies.

Question 30 (CISM7-087)

Scenario: A design studio restricts access to project repositories, but authorized users can copy designs into unmanaged messaging tools. The risk scenario includes disclosure after access is granted.

Which control-design response BEST addresses the exposure?

- A. Accept the design because repository permissions work.
- B. Reassess end-to-end coverage and add proportionate controls for copying, messaging, monitoring, retention, and disposal.
- C. Increase repository password length.
- D. Transfer control ownership to internal audit.

Question 31 (CISM7-088)

Scenario: A consulting firm can block all external file sharing or use classification-aware restrictions, approvals, prompts, and monitoring. Both reduce risk but affect client work differently.

Which evaluation basis should guide the choice?

- A. Select the option with the most individual settings.
- B. Use the lowest initial purchase price.
- C. Choose the design most heavily promoted by a supplier.
- D. Compare risk-scenario coverage, false blocks, workflow impact, failure modes, maintainability, response capacity, and total cost.

Question 32 (CISM7-089)

Scenario: A construction company configures automated expiration for supplier accounts. Business owners have not agreed who sets end dates, resolves disputes, or handles emergency extensions.

What must be completed before the control is considered implemented?

- A. Use of the remaining project budget
- B. A vendor statement that the software is installed
- C. Transfer of routine account decisions to internal audit
- D. Accountable roles, source-data responsibilities, procedures, exception handling, training, support, and acceptance evidence

Question 33 (CISM7-090)

Scenario: A local government involves security only during final testing of new citizen services. Late findings repeatedly delay launch and require contract changes.

Which program change would MOST improve delivery?

- A. Embed proportionate requirements, design review, procurement checks, testing, and acceptance from project initiation through release.
- B. Let suppliers define security requirements independently.
- C. Increase the duration of final testing only.
- D. Approve releases automatically when deadlines are fixed.

Question 34 (CISM7-091)

Scenario: A law office deploys secure-release printing, but employees use nearby unmanaged printers because release stations are distant and frequently unavailable.

Which initial adoption response is MOST appropriate?

- A. Remove all printing controls.
- B. Declare implementation successful because secure printers exist.
- C. Send more reminders without addressing availability.
- D. Correct service-access barriers and manage interim risk

Question 35 (CISM7-092)

Scenario: A retailer pilots stronger workforce authentication at corporate offices. Stores use shared devices, seasonal staff, and limited local support, none of which were included in the pilot.

Which deployment decision BEST reflects the evidence?

- A. Deploy to every store immediately because the office pilot passed.
- B. Validate representative store workflows, device use, support, acceptance criteria, and rollback before phased expansion.
- C. Cancel the control because the first pilot was limited.
- D. Let each store decide whether stronger authentication applies.

Question 36 (CISM7-093)

Scenario: A company records privileged sessions for critical systems. Existing testing confirms that the recording service is online but not that all accounts and systems are covered or recordings are reviewed.

Which test design is MOST appropriate?

- A. Confirm only that the recording policy is approved.
- B. Verify population completeness, recording integrity, reviewer authority, timely review, exceptions, retention, and corrective action.
- C. Count the number of dashboard users.
- D. Rely on the control operator's general assurance.

Question 37 (CISM7-094)

Scenario: Testing identifies a common authentication defect affecting many critical services and several isolated low-risk documentation errors. All findings currently have identical deadlines.

Which remediation approach is MOST appropriate?

- A. Address findings in the order they were entered.
- B. Use the same deadline regardless of exposure.
- C. Prioritize by risk, systemic reach, dependencies, root cause, and feasible sustainable correction.
- D. Let each finding owner choose a severity.

Question 38 (CISM7-095)

Which assurance arrangement provides the STRONGEST objectivity?

- A. A competent party independent of operation selects suitable evidence and reports through an appropriate governance route.
- B. The owner prevents reviewers from examining exceptions.
- C. Independent review replaces all management monitoring.
- D. The operator selects only successful samples and approves the conclusion.

Question 39 (CISM7-096)

Scenario: A transaction control is considered effective because it passed testing two years ago. Business rules, data sources, and transaction channels have changed substantially since then.

Which assurance conclusion should the information security manager reach?

- A. Evaluation should wait for a confirmed financial loss.
- B. The original test proves continued effectiveness.
- C. Automated controls do not require testing after launch.
- D. Historical evidence is insufficient; current design, change coverage, population, operation, exceptions, and outcomes require evaluation.

Question 40 (CISM7-097)

Which measure BEST demonstrates awareness effectiveness?

- A. Number of awareness messages sent
- B. Improvement in the targeted behavior and reduction in the associated risk indicator
- C. Percentage of employees invited to training
- D. Length of the annual course

Question 41 (CISM7-098)

Scenario: Procurement staff complete general security training but frequently omit required security terms when urgent purchases use shortened contract workflows.

Which procurement-training improvement is MOST appropriate?

- A. Repeat the same general course for every employee.
- B. Measure success only through attendance.
- C. Make security staff negotiate every contract.
- D. Use role-based scenarios, reinforce expectations, and measure behavior

Question 42 (CISM7-099)

Scenario: Employees report suspicious calls more often, but regional service desks still reset high-risk accounts without complete verification during peak periods.

Which awareness action should the manager take NEXT?

- A. Declare the program successful based on reporting volume.
- B. Stop measuring behavior because indicators differ.
- C. Analyze peak-workflow causes, provide targeted reinforcement and process support, and measure verification behavior by region.
- D. Send identical additional content to every role.

Question 43 (CISM7-100)

Scenario: A subscription business plans to outsource customer support with access to billing and account data. Procurement has reviewed cost but not security evidence, access, incidents, subcontractors, or termination.

Which provider requirement is MOST appropriate?

- A. A general confidentiality clause as the only safeguard
- B. Transfer of customer-data ownership to the provider
- C. Approval based only on provider reputation
- D. Risk-based due diligence and defined access, evidence, incident, subcontractor, monitoring, continuity, retention, and exit terms

Question 44 (CISM7-101)

Scenario: Several payroll and benefits providers depend on the same document-processing subcontractor. Each provider passed separate review, but the combined dependency is unknown.

Which fourth-party analysis should occur FIRST?

- A. Assume separate approvals address the shared dependency.
- B. Wait for an outage before changing oversight.
- C. Take operational control of the subcontractor.
- D. Assess aggregate business impact, concentration, resilience, contractual visibility, alternatives, and monitoring needs.

Question 45 (CISM7-102)

Scenario: An engineering company is leaving a hosted design repository. Files can be exported, but permissions, revision history, encryption metadata, and deletion evidence are not included.

Which repository exit approach is BEST?

- A. Test transfer, continuity, revocation, deletion, and accountable acceptance
- B. Terminate immediately and reconstruct missing history later.
- C. Keep both repositories indefinitely.
- D. Rely on a verbal assurance that remaining copies are protected.

Question 46 (CISM7-103)

Scenario: Operations leaders receive a security report containing patch and alert totals but cannot identify threatened services, accountable owners, or required decisions.

Which dashboard design would BEST support action?

- A. Add every raw alert for leaders to investigate.
- B. Remove negative trends until remediation is complete.
- C. Show trends against program outcomes and thresholds, business-service impact, accountable owners, actions, and decisions.
- D. Report only activities performed by the security team.

Question 47 (CISM7-104)

Scenario: Two business units dispute ownership of a shared control. Remediation is overdue, risk exceeds an approved threshold, and the security manager cannot assign business ownership.

Which ownership escalation response is MOST appropriate?

- A. Escalate through the defined governance path with evidence, impact, ownership options, and the decision required.
- B. Assign the security team as permanent control owner.
- C. Move the due date so the issue appears current.
- D. Omit the dispute until the units agree.

Question 48 (CISM7-105)

Scenario: A security roadmap requires changes during a retailer's peak season. Business leaders support the objective but reject the timing because they were not involved in planning.

Which engagement approach would BEST resolve the issue?

- A. Remove every business-dependent initiative from the program.
- B. Enforce the original dates without considering business impact.
- C. Jointly review outcomes, risk, operational dependencies, timing alternatives, responsibilities, and decision criteria.
- D. Let each unit define unrelated security outcomes.

Question 49 (CISM7-106)

Scenario: A credit union adds video-based customer service. Existing controls assume branch or telephone interactions and do not cover recorded sessions, visual documents, or the new platform provider.

Which maintenance action should occur FIRST?

- A. Apply telephone procedures unchanged to video interactions.
- B. Exclude video service from the security program.
- C. Assess changed workflows, information, ownership, threats, obligations, and dependencies, then update program controls and measures.
- D. Wait for customer complaints before revising controls.

Question 50 (CISM7-107)

Scenario: An aerospace supplier wants networked additive-manufacturing systems to use confidential design files. Equipment support, supplier access, integrity monitoring, and data lifecycle controls are unclear.

Which additive-manufacturing governance approach is MOST appropriate?

- A. Permit unrestricted deployment until a confirmed failure occurs.
- B. Set supplier guardrails, run a pilot, monitor outcomes, and update controls
- C. Ban the technology permanently because existing standards do not name it.
- D. Allow each facility to create unrelated security rules.

Answer Key

Domain III - Information Security Program

1 B	2 A	3 A	4 D	5 C
6 B	7 A	8 D	9 B	10 D
11 B	12 C	13 C	14 A	15 C
16 D	17 B	18 C	19 B	20 A
21 B	22 C	23 B	24 A	25 C
26 A	27 D	28 A	29 A	30 B
31 D	32 D	33 A	34 D	35 B
36 B	37 C	38 A	39 D	40 B
41 D	42 C	43 D	44 D	45 A
46 C	47 A	48 C	49 C	50 B

Detailed Explanations

Question 1 (CISM7-058)

Correct answer: B - The service model, data uses, customer obligations, technology dependencies, and resulting risks

Objectives should reflect the new service, information use, obligations, dependencies, and exposure. Existing tools and competitor practices are only inputs, while avoiding operational change may leave material risk untreated.

Question 2 (CISM7-059)

Correct answer: A - Approve a program charter defining objectives, scope, decision rights, responsibilities, sponsorship, and escalation across both institutions.

A jointly approved charter resolves the missing mandate and accountability across institutions. Standards require underlying authority, providers cannot own the entire program, and project-specific governance would create fragmentation.

Question 3 (CISM7-060)

Correct answer: A - Reassess expansion risks and dependencies, then resequence funded capabilities around the launch milestones.

The accelerated expansion changes both risk and required capability timing, so the roadmap should be reassessed and transparently resequenced. A fixed or unfunded plan is unrealistic, while post-launch treatment leaves known gaps.

Question 4 (CISM7-061)

Correct answer: D - Map the end-to-end service, data, obligations, dependencies, risks, and responsibilities at each interface.

Scope should follow the complete service and information risk, with accountability defined across organizational boundaries. Ownership limits and vendor operation do not remove exposure, and no single participant can automatically own all risk.

Question 5 (CISM7-062)

Correct answer: C - Asset scope, risk tiers, demand, service targets, skills, and automation

Capacity should be based on actual scope, risk, workload, service expectations, competence, and automation. Reporting lines, market offerings, and peer budgets do not establish this program's operational needs.

Question 6 (CISM7-063)

Correct answer: B - Use qualified external drafting and research support under internal ownership, review, approval, and knowledge-transfer requirements.

External support can add capacity while internal management retains authority, context, and accountability and builds knowledge. Consultants cannot accept organizational risk, delay creates stale documents, and audit should remain independent.

Question 7 (CISM7-064)

Correct answer: A - A business case covering risk reduction, process benefits, ownership and data prerequisites, implementation effort, and total cost

The business case must address value and the process, ownership, data, and implementation prerequisites needed to achieve it. Price and feature counts are incomplete, while eliminating every failure is not a credible outcome.

Question 8 (CISM7-065)

Correct answer: D - Create a competency plan combining targeted development, recruitment, succession, and selective external support.

A competency plan connects specific capability gaps to appropriate workforce options and timing. Generic training and salary-based hiring are not targeted, while internal audit should not operate management capabilities.

Question 9 (CISM7-066)

Correct answer: B - The information custodian

The custodian implements owner-defined handling and protection requirements. Committees and policy approvers provide governance, while auditors independently assess rather than operate controls.

Question 10 (CISM7-067)

Correct answer: D - Record business purpose, accountable owner, source information, classification, location, dependencies, and lifecycle status.

Derived data remains an information asset and needs business context, ownership, provenance, sensitivity, location, dependencies, and lifecycle status. Platform-only and audit-only views are incomplete, while administrators are not automatically business owners.

Question 11 (CISM7-068)

Correct answer: B - Define classification-based handling requirements and embed them in recording, transcription, sharing, and disposal workflows.

Classification-based workflow rules make protection consistent across the recording lifecycle. Indefinite uniform handling ignores differing needs, central approval will not scale, and recording volume does not demonstrate appropriate protection.

Question 12 (CISM7-069)

Correct answer: C - Confirm accountable ownership and applicable business, contractual, ethical, and legal requirements before controlled disposition.

Ownership and applicable requirements must be established before defensible retention, transfer, restriction, or deletion decisions. Immediate deletion and indefinite storage can both create risk, while administrators lack sole business authority.

Question 13 (CISM7-070)

Correct answer: C - A structured reference for organizing and assessing relevant security capabilities

A framework provides structured guidance for organizing and assessing capabilities when adapted to context. It does not accept risk, guarantee universal compliance, or require identical technologies.

Question 14 (CISM7-071)

Correct answer: A - Its fit with organizational objectives, risks, obligations, capabilities, and governance

Framework selection should be based on organizational fit and the outcomes it can support. Length and supplier preference are weak criteria, and no framework removes the need for contextual tailoring.

Question 15 (CISM7-072)

Correct answer: C - Map requirements to a common control and evidence model while retaining traceability to unique obligations.

A common control and evidence model reduces duplication while preserving accountability for distinct obligations. Discarding requirements creates gaps, separate implementation wastes effort, and the shortest framework is not necessarily sufficient.

Question 16 (CISM7-073)

Correct answer: D - Standard

A standard establishes specific mandatory requirements supporting policy. Guidelines are advisory, procedures describe execution, and roadmaps sequence program initiatives.

Question 17 (CISM7-074)

Correct answer: B - To show that operational steps implement authorized requirements and can be maintained consistently

Traceability shows that procedures implement authorized requirements and supports consistent maintenance. It does not make procedures universal, freeze them, or grant authors risk-acceptance authority.

Question 18 (CISM7-075)

Correct answer: C - Documented risk, accountable approval, compensating reviews, monitoring, review triggers, and a defined expiration

A controlled exception must be risk-based, authorized, protected, monitored, and time-limited. Permanent exclusion and informal approval evade governance, while incident history does not establish acceptable future exposure.

Question 19 (CISM7-076)

Correct answer: B - Engage accountable owners to reconcile the requirements using business and risk needs, then approve and communicate aligned rules.

The conflict requires an authorized, risk-based resolution and consistent communication. Individual choice and publication date do not establish authority, while suspending all remote work is disproportionate before resolving the specific requirement.

Question 20 (CISM7-077)

Correct answer: A - Define security principles and shared capability requirements aligned with the target enterprise architecture and risk scenarios.

Aligned principles and capabilities provide coherent guidance before project decisions become fixed. Product uniformity does not guarantee architecture fit, separate principles create fragmentation, and late definition causes redesign.

Question 21 (CISM7-078)

Correct answer: B - Create a gap and dependency analysis defining transition states, interim safeguards, owners, priorities, and convergence milestones.

A structured transition analysis makes convergence achievable while governing temporary exposure and dependencies. Permanent exceptions defeat the target, immediate migration may be unsafe, and a product inventory is not an architecture roadmap.

Question 22 (CISM7-079)

Correct answer: C - Links from approved data requirements to architecture decisions, data flows, control ownership, and acceptance criteria

Traceability shows how requirements constrain collection and use through architecture and accountable controls. Hardware lists and trend statements do not establish alignment, and the organization retains architecture governance.

Question 23 (CISM7-080)

Correct answer: B - Introduce risk-tiered reviews, reusable patterns, early engagement, and a governed exception route.

Risk tiers and reusable patterns make oversight scalable while retaining requirements and accountable exceptions. Broad exclusion and cost-only review can miss material exposure, while audit should remain independent of design.

Question 24 (CISM7-081)

Correct answer: A - Compare resilience, dependencies, interim controls, impact, cost, and exit criteria

A sound roadmap balances target benefits with transition risk, clinical resilience, dependencies, support, and cost. Speed alone is inadequate, indefinite delay preserves gaps, and separate targets perpetuate fragmentation.

Question 25 (CISM7-082)

Correct answer: C - Trend in material defects escaping to production, segmented by service risk and development stage

Material defect escape rates show whether the development process is preventing or finding weaknesses before production. Slides, configuration effort, and meeting counts are activities rather than security outcomes.

Question 26 (CISM7-083)

Correct answer: A - Trends by subsidiary, service criticality, accountable owner, backlog age, exception, and root cause

Segmented risk and ownership data exposes material pockets hidden by the average and supports targeted action. Dashboard appearance, policy length, and report views do not explain control performance.

Question 27 (CISM7-084)

Correct answer: D - Set differentiated targets using risk, business dependence, desired outcomes, dependencies, affordability, and expected value.

Target maturity should be appropriate to each capability's business and risk context rather than uniformly maximal. Low scores alone do not establish investment value, while maturity remains a useful contextual input.

Question 28 (CISM7-085)

Correct answer: A - It addresses a defined objective and risk within applicable requirements and operating constraints.

A suitable design is traceable to the intended objective and risk and fits business and architecture conditions. Novelty, peer similarity, and maximum restriction do not demonstrate effectiveness or proportionality.

Question 29 (CISM7-086)

Correct answer: A - Design accessible alternative verification with accountability and monitoring

A risk-based design should reduce fraud while providing governed, accessible alternatives for legitimate users. Maximum restriction can create service harm, while removing or making verification optional abandons the objective.

Question 30 (CISM7-087)

Correct answer: B - Reassess end-to-end coverage and add proportionate controls for copying, messaging, monitoring, retention, and disposal.

The control set must address the entire information path, including authorized copying and downstream sharing. Repository controls and password changes do not cover that exposure, while audit should assess rather than own controls.

Question 31 (CISM7-088)

Correct answer: D - Compare risk-scenario coverage, false blocks, workflow impact, failure modes, maintainability, response capacity, and total cost.

The decision should balance effective coverage with operational errors, workflow impact, resilience, maintainability, and total cost. Setting counts, marketing, and purchase price alone are insufficient.

Question 32 (CISM7-089)

Correct answer: D - Accountable roles, source-data responsibilities, procedures, exception handling, training, support, and acceptance evidence

Implementation requires a complete operating model with reliable inputs, ownership, procedures, competence, exceptions, and validated readiness. Installation and spending are insufficient, while audit should remain independent of operation.

Question 33 (CISM7-090)

Correct answer: A - Embed proportionate requirements, design review, procurement checks, testing, and acceptance from project initiation through release.

Lifecycle integration lets risk and requirements influence decisions when change is feasible. Larger late tests preserve the timing problem, suppliers do not own requirements, and fixed deadlines do not justify automatic approval.

Question 34 (CISM7-091)

Correct answer: D - Correct service-access barriers and manage interim risk

The program should correct practical barriers that prevent intended behavior while governing interim exposure. Availability of the control is not adoption, reminders do not fix service gaps, and removing controls abandons the objective.

Question 35 (CISM7-092)

Correct answer: B - Validate representative store workflows, device use, support, acceptance criteria, and rollback before phased expansion.

A phased rollout should extend evidence to store conditions and confirm support and recovery readiness. Office results cannot simply be generalized, cancellation discards a viable control, and local discretion weakens consistent governance.

Question 36 (CISM7-093)

Correct answer: B - Verify population completeness, recording integrity, reviewer authority, timely review, exceptions, retention, and corrective action.

Testing should determine whether the control covers the intended population and operates with complete, reviewed, retained evidence and managed exceptions. Policy approval, dashboard counts, and operator assertions are insufficient.

Question 37 (CISM7-094)

Correct answer: C - Prioritize by risk, systemic reach, dependencies, root cause, and feasible sustainable correction.

Risk and systemic reach should focus attention on the shared critical defect while accounting for dependencies and durable remediation. Submission order, uniform deadlines, and ungoverned owner preference do not reflect exposure.

Question 38 (CISM7-095)

Correct answer: A - A competent party independent of operation selects suitable evidence and reports through an appropriate governance route.

Independence from operation, suitable evidence selection, and an appropriate reporting path support objective assurance. Operator-controlled samples and evidence restrictions create bias, while independent review complements rather than replaces management monitoring.

Question 39 (CISM7-096)

Correct answer: D - Historical evidence is insufficient; current design, change coverage, population, operation, exceptions, and outcomes require evaluation.

Material changes can invalidate old assurance, so current coverage and sustained operation must be tested. Automation does not remove assurance needs, and waiting for loss is reactive.

Question 40 (CISM7-097)

Correct answer: B - Improvement in the targeted behavior and reduction in the associated risk indicator

Behavioral improvement and reduced targeted exposure demonstrate the intended outcome. Message volume, course length, and invitations measure activity rather than effectiveness.

Question 41 (CISM7-098)

Correct answer: D - Use role-based scenarios, reinforce expectations, and measure behavior

Role-specific learning and decision-time prompts address the actual contracting risk and enable behavioral measurement. Generic repetition and attendance are indirect, while security cannot replace procurement in every negotiation.

Question 42 (CISM7-099)

Correct answer: C - Analyze peak-workflow causes, provide targeted reinforcement and process support, and measure verification behavior by region.

The segmented evidence identifies a specific behavior and operating context requiring targeted analysis, reinforcement, and follow-up measurement. Reporting alone does not negate the gap, and generic action may miss its cause.

Question 43 (CISM7-100)

Correct answer: D - Risk-based due diligence and defined access, evidence, incident, subcontractor, monitoring, continuity, retention, and exit terms

The service requires lifecycle governance proportionate to customer-data and account risk. A single clause and reputation are insufficient, while the organization retains information ownership and accountability.

Question 44 (CISM7-101)

Correct answer: D - Assess aggregate business impact, concentration, resilience, contractual visibility, alternatives, and monitoring needs.

Separate reviews can miss enterprise concentration risk, so the shared dependency requires aggregate analysis. Existing approvals are not conclusive, direct operation is inappropriate, and waiting for failure is reactive.

Question 45 (CISM7-102)

Correct answer: A - Test transfer, continuity, revocation, deletion, and accountable acceptance

A complete exit preserves usable data and its protection context while ending access and verifying deletion. Immediate termination can strand information, indefinite duplication increases exposure, and verbal assurance is weak evidence.

Question 46 (CISM7-103)

Correct answer: C - Show trends against program outcomes and thresholds, business-service impact, accountable owners, actions, and decisions.

Decision-oriented reporting links program performance to risk, business services, accountability, and needed action. Raw detail obscures priorities, while hiding results or limiting scope impairs oversight.

Question 47 (CISM7-104)

Correct answer: A - Escalate through the defined governance path with evidence, impact, ownership options, and the decision required.

The material exposure and missing authority require transparent escalation to the accountable decision body. Security should not assume business ownership, and changing dates or withholding the issue conceals risk.

Question 48 (CISM7-105)

Correct answer: C - Jointly review outcomes, risk, operational dependencies, timing alternatives, responsibilities, and decision criteria.

Joint planning preserves the security objective while incorporating real dependencies and clarifying shared decisions. Unilateral timing may fail operationally, removal leaves risk untreated, and unrelated outcomes fragment the program.

Question 49 (CISM7-106)

Correct answer: C - Assess changed workflows, information, ownership, threats, obligations, and dependencies, then update program controls and measures.

The new channel changes information, actors, technology, and provider dependencies, requiring a structured program update. Reusing old procedures without analysis may misfit, exclusion abandons governance, and waiting is reactive.

Question 50 (CISM7-107)

Correct answer: B - Set supplier guardrails, run a pilot, monitor outcomes, and update controls

Governed experimentation supports business learning while addressing design integrity, data, architecture, and supplier risk and feeding evidence into program improvement. Unrestricted use lacks safeguards, a permanent ban avoids proportionate assessment, and local rules fragment governance.